

QK2 Recovery Decision

The recovery architecture is *settled as product direction*: a native 2-of-3 P2WSH wallet across three custody objects — Recovery Document A1 (encrypted), Key Card B, and Emergency Card/Kit C — plus an interchangeable terminal. Selecting this model is done; nothing here is implemented or validated. The stop-ship that remains is **rehearsal with real cards, documents, devices, and transactions**.

ARCHITECTURE	WALLET	OBJECTS	SEED A	REHEARSAL	DATE
selected	2-of-3 P2WSH	A1 · B · C + device	A1 ciphertext only	stop-ship · open	2026-08-17

PROJECT STATUS — ARCHITECTURE SELECTED, REHEARSAL OPEN

- Air-gapped calculator-disguised 2-of-3 co-signer. Three custody objects: **A1** = an ordinary printed webpage carrying authenticated *ciphertext* of 256-bit Seed-A entropy; **B** = bus-pass-style Key Card (Seed B + the A2 key); **C** = Emergency Card/Kit (independent Seed C + the same A2). The terminal holds no persistent wallet secret and is interchangeable.
- **No card PIN / duress / lockout.** B and C are bearer objects; physical custody plus the 2-of-3 threshold is the spending control. Stealth is a first layer of defence, never a cryptographic factor and never a substitute for the threshold.
- **Selecting the architecture is done; rehearsing it is not.** No funds under any descriptor until the loss matrix is rehearsed with real artifacts. All witnesses/spends here are reference computations needing independent finalization and `testmempoolaccept` before any "works" claim.

1. [The decision, restated](#)
2. [The selected architecture](#)
3. [Why 2-of-3](#)
4. [The recovery bundle](#)

5. [The loss / recovery matrix](#)
6. [Kit tiers](#)
7. [Rejected alternatives](#)
8. [Decision date](#)

01 THE DECISION

Why the plain 2-of-2 was reopened – and settled as 2-of-3

A plain `wsh(sortedmulti(2,A,B))` has no way to spend if the smart card holding key B is lost or bricked. An earlier draft presented a Seed-A miniscript timelock as "resolving" this; that was an overstatement, and the timelock is now a [rejected alternative](#). The settled product direction is a native **2-of-3 P2WSH** across three custody objects with an interchangeable terminal. This preserves a two-signing-factor threshold at all times, needs no custom script or key export, and is recoverable with independent third-party software. Selecting it is done; the open work is rehearsal.

SEED A LIVES ONLY AS A1 CIPHERTEXT

Seed A is never stored as naked words. It exists only as **A1** — authenticated *ciphertext* printed in the footer of an ordinary-looking webpage — plus **A2**, a fresh 256-bit random key generated at provisioning and duplicated onto *both* cards B and C (then wiped from the terminal). To use the A leg, a bearer card releases A2, the replaceable terminal decrypts A1 to recover Seed A, and A signs alongside B (or C). A2 is not a Bitcoin signing key and is exportable from a card by design; Seeds B and C never leave their cards. This removes the old single-card "Vault Key" dependency: because A2 lives on both bearer cards, losing one card never destroys the route to Seed A — but losing *both* cards destroys A2 and with it the A leg (see the matrix).

02 THE ARCHITECTURE

Four elements: three custody objects + an interchangeable device

ELEMENT	WHAT IT IS	CARRIES	EXPORTABLE?
A1 · Recovery Document	an ordinary printed webpage (recipe / guitar tab / travel note) whose footer resembles the page's source URL	authenticated ciphertext of 256-bit Seed-A entropy — no naked words, no crypto label	n/a (ciphertext)
A2 · Decryption key	a fresh 256-bit random key made at provisioning; not a Bitcoin key	the key that decrypts A1 — duplicated onto both B and C, wiped from the terminal	yes, by design
B · Key Card	bus-pass-style smart card, normal signer	least-authority account xprv for signer B (m/48h/0h/0h/2h) + A2 + descriptor D — no root mnemonic on the card	signer key never
C · Emergency Card / Kit	second bus-pass card + recovery / inheritance materials	independent account xprv for signer C + the <i>same</i> A2 + descriptor D — no root mnemonic on the card	signer key never
Device · Terminal	retro-calculator terminal, interchangeable	no persistent wallet secret; at provisioning generates A2+A1, writes A2 to B and C, verifies both, then wipes A2 and all seeds	holds nothing at rest

```
wsh(sortedmulti(2, A, B, C))  - native P2WSH, selected product direction
```

```
  A = transient Seed-A signer (A1 ciphertext decrypted with A2 from a bearer card)
```

```
  B = Key Card signer (Seed B)
```

```
  C = Emergency Card / Kit signer (independent Seed C)
```

```
normal:  A1 + B      B lost: A1 + C      A1 lost: B + C (A bypassed)      any lost factor: spend once, then fresh kit + sweep
```

Ordinary P2WSH multisig with `sortedmulti` — no custom satisfaction path, no per-UTXO age, no sequence construction, recoverable with independent software (Sparrow, Bitcoin Core, Nunchuk). It requires a two-signer-factor threshold at all times and needs no seedment. Seeds A, B and C are

preserves a two-signing-factor threshold at all times and needs no seed export. Seeds A, B and C are **domain-separated at acquisition** — B and C are not derived from A or from one master; each gets fresh entropy — 24 words / 256 bits, the sole production profile. A2 is generated independently, also 256-bit.

NO PIN, NO DURESS, NO LOCKOUT

B and C are **bearer objects**: whoever holds the card can use it, and the 2-of-3 policy is the spending control — not a card PIN, retry-counter, duress code, or bricking mechanism. This matters most for **C**: an inheritance kit must still work after years, with no forgotten PIN, dead vendor, closed account, or drifted clock. Stealth (the disguised document, the calculator form factor, unlabelled cards) is a first layer of defence only — never a cryptographic factor, never a substitute for the threshold.

Reference 2-of-3 spine — a reference computation, NOT canonical (regenerated fixture values).

fingerprints A=2fae9711 B=72a14ab8 C=badaa8ff

descriptor checksum #kuyqfyj3

leg C origin/xpub [badaa8ff/48h/0h/0h/2h]xpub6EPnBYhH8bEknocsxAw8VtsVYzMT1sBgbUFSpwikQMCMYhV1tQ38TbhrHuDVLbeeodE99AA9x8LEHjLs

receive /0/0 bc1qecahkw0srs8xpmgwqya49qtknxwkwrt0ky4jds52scsw4etmd6s5s93pr

The old 2-of-2 (#w9nvs8vx) is retained only as a historical / regression fixture.

03 RATIONALE

Why 2-of-3 with an independent C

2-of-3 keeps normal spending A1+B, permits recovery A1+C, permits a device-free B+C path if the document is lost, preserves a two-signing-factor requirement at all times, and avoids any seed export or custom script. It is broadly understandable and recoverable with independent tooling — the properties a recovery story most needs. **C must be genuinely independent**: its Seed C is generated separately (not

derived from Seed A/B or one master), and the C KIT is stored not co-located with the A1 document. A2 being duplicated on both B and C is deliberate: it is the decryption key for A1, not a signing factor, so copying it does not weaken the 2-of-3 threshold.

NOT RETROFITTABLE

The 2-of-3 script is a specific descriptor: coins funded under any other policy cannot gain this recovery structure without being swept into the new descriptor. Because a wallet-policy change is not retrofittable, the policy is fixed **before the descriptor is settled and the first coin lands**. The architecture is now selected precisely so the descriptor can be settled — but only *after* the loss matrix is rehearsed (see the gate).

3B THE RECOVERY BUNDLE

The seeds are not enough – the descriptor must survive too

Recovering Seed A and holding a card does **not** by itself let you spend a 2-of-3 output. Any two-of-three spend still needs the other legs' *public* keys inside the witness script, plus the exact threshold, script type, network, and derivation. Seed backups alone don't identify scripts — precisely the problem output descriptors (BIP-380) exist to solve. So the recovery bundle is the custody objects themselves — A1's ciphertext and the two bearer cards — *and* the complete descriptor record **D**.

DESCRIPTOR D – WHAT MUST SURVIVE INDEPENDENTLY OF EVERY DEVICE

The complete checksummed policy record: two ordinary checksummed receive/change descriptors as the conservative authority; **all A/B/C xpubs** + fingerprints + full origins; threshold, script type, network, derivation; policy version; birthday (for rescan); first receive/change addresses; and recovery/rotation instructions. Sealing it only on a card and assuming a

coordinator still holds a copy is **not** a durable backup. A descriptor checksum is *error-detection, not authentication* — an attacker can build a different valid descriptor with a valid checksum — so at provisioning the terminal must derive and compare every A/B/C origin/xpub from the **actual factors**, show a compact policy identity + first addresses, and require a scan-back / re-import rehearsal. BIP-389 multipath is an optional convenience, not the sole decades-long authority.

BACKUP	NATURE	CONTENTS & HANDLING
Seed A	ciphertext only	lives only as A1 — authenticated ciphertext in the disguised document footer. No naked BIP-39 words for A anywhere. Reconstructed transiently by decrypting A1 with A2 (from B or C) on the replaceable terminal.
Seed B / Seed C	secret	the two bearer signers. Each is generated on the terminal from independent 256-bit entropy, but only a least-authority account xprv (m/48h/0h/0h/2h + chain code + origin) is loaded onto its bearer card; the root mnemonic is wiped once the account xpub is confirmed. There is <i>no</i> stored word-list — B and C are recovered through the surviving threshold pair and the open card/rescue protocol, never by exporting a seed from a card.
A2 · decryption key	key material	duplicated on B and C. Useless alone: without the A1 ciphertext it decrypts nothing, and Seed A is still only one of three factors.
Descriptor D	privacy-sensitive	the complete policy record above. Not "public, copy widely" — its xpubs expose EC public keys (BIP-360 warns). Held offline + encrypted at rest, no cloud sync. Coordinator disclosure is tiered: Simple Recovery and Inheritance may export the full watch-only descriptor to a supported coordinator; only Quantum Shelter restricts the online side to individual P2WSH receive addresses. Placement differs by kit tier (see §tiers).

INTEGRITY AT RECOVERY IS BY DERIVATION, NOT JUST A CHECKSUM

Seed A arrives from an authenticated decryption of A1. The crypto capsule is frozen: **ChaCha20-Poly1305 (RFC 8439)** with a fresh stored **96-bit nonce** and **128-bit tag**, document key = HKDF-SHA256(IKM=A2, salt=wallet_id, info="QuietKey/A1/v1") , plaintext exactly the 32-byte Seed-A entropy, with the version fields, network and full wallet_id bound as AAD; **no plaintext is released before the tag verifies**. Beyond that, accept a recovery only when every restored factor's derived origin/xpub matches D, and during recovery the D-derived scripts must match the funded UTXOs. The AEAD

runs on the replaceable terminal — never coupled to whatever cipher one JavaCard happens to expose — while a bearer card only releases A2 over a minimal card session.

Gate A must test the **real disguised printed webpage**, not a codec in the abstract: URL plausibility, font, aging, folds, stains, photocopies, capture angle, false-accept rate, a manual fallback, and whether ordinary observers even notice the footer. Recompute any RS / base32 / length / layout only after the AEAD capsule length is settled.

04 LOSS MATRIX

Every row must be rehearsed with real artifacts before descriptor freeze

Run this with actual cards, documents, devices, and finalized transactions — not descriptions. Flows are fixed to **A1+B / A1+C / B+C**. The threshold needs two of the three signing factors (Seed A, Seed B, Seed C); **losing two signing factors can be unrecoverable — stated plainly below.**

EVENT	REQUIRED SAFE OUTCOME	FLOW / OUTCOME
Key Card B lost	recover without B and without any secret stored only on B	A1 + C — C holds A2, decrypt A1 → Seed A, sign A+C once, then provision a fresh A/B/C/A2/D' kit and sweep (B is never reissued)
Recovery Document A1 lost	funds safe; documented path with remaining factors	B + C — Seed A is unreconstructable (A bypassed), sign B+C once, then provision a fresh kit and sweep; A1 is never re-issued — a replacement factor means a new descriptor
Emergency Card / Kit C lost	normal spending still works; re-provision before another loss	A1 + B once, then provision a fresh kit and sweep — replacing C changes the descriptor, so the whole wallet is re-provisioned

A2 copy compromised	state exactly what the attacker gains	A2 alone decrypts nothing — with A1 too, attacker gets Seed A = one factor only; still needs B or C
Descriptor D lost (all copies)	seeds alone must not be assumed sufficient	depends on factors — with all three factors in hand the fixed 2-of-3 policy lets D be rebuilt; if any factor is also missing the witness script / xpubs are gone, so D-survival stays a stop-ship
Terminal lost / destroyed	recover with a rebuilt QK2 or independent tooling	just replace — no persistent secret, not a spending factor, interchangeable
Two signing factors lost	explicitly recoverable or explicitly not — no ambiguity	unrecoverable — e.g. A1 + B lost (only C left), or both cards lost (A2 gone, so the A leg dies too)
QR capture fails / microSD write fails	original PSBT intact; the other transport still completes	use the other transport — both required; microSD is the lower-risk first path; QR remains a HW/system validation blocker
Card cloned	detection is NOT automatic	only with non-exportable seeds, a unique provisioned identity, an external counter anchor + user action, and an independently-remembered expected state
Inheritance (owner deceased)	heir spends with no PIN, vendor, account, or clock dependency	C kit + A1 (or B) — bearer objects, 2-of-3, D placed per the Inheritance tier
Interrupted provisioning / signing	no funded ambiguous wallet; deterministic resume; original PSBT intact	ceremony + transport lifecycle test

A2 lives only on the bearer cards, so losing both B and C also destroys A2 — the A leg then cannot be decrypted even if A1 survives. Guard the two cards accordingly.

05 KIT TIERS

Same crypto – different packaging,

instructions, and D placement

All tiers share the identical threshold, 24-word / 256-bit seeds, no-PIN bearer model, native P2WSH script, and entropy discipline. They differ only in packaging, instructions, redundancy, and where the descriptor record D is placed. Coordinator disclosure is also tiered: Simple Recovery and Inheritance may export the full watch-only descriptor to a supported coordinator, while only the Quantum Shelter tier restricts the online side to address packs.

TIER	FOR	PACKAGING & REDUNDANCY	D PLACEMENT
Simple Recovery Kit	a single owner who wants a robust backup	minimal: card B in use, C kit stored off-site; concise instructions	D on B and C, plus a redundant A2-encrypted cloaked copy
Inheritance Kit	hand-off to an heir after years	fuller: plain-language heir instructions, a redundant cloaked D record, where-to-find notes; must work with no PIN / vendor / account / clock	D on B and C, plus a redundant A2-encrypted cloaked copy
Quantum Shelter (Deep Cold) Kit	long-dormant, quantum-prepared holdings	deepest cold: cloaked/encrypted "wallet map", minimal online footprint; the signed output is a finalized raw transaction (no PSBT xpub/origin metadata back online)	D kept as a separate cloaked/encrypted wallet map ; the online side sees receive addresses only

QUANTUM-PREPARED, NOT QUANTUM-PROOF

256-bit seeds + encryption, dormant P2WSH keys/descriptors offline, and no address reuse buy long-exposure safety (a P2WSH output commits to the SHA256 of the witness script and reveals script/keys only when spent). This is preparation, not immunity: 24 words protect seed brute-force, not ECDSA/Shor; do **not** use Taproot for the vault (P2TR exposes an EC output key immediately); do not bolt an off-chain PQ signature onto a PSBT and market it as protection. Migration trigger: sweep from the hidden-key P2WSH outputs when a credible reviewed PQ output/signature path deploys or CRQC progress changes the horizon.

06 REJECTED ALTERNATIVES

Considered and rejected – kept only for the record

ALTERNATIVE	WHY REJECTED
Seed-A relative timelock	after the delay Seed A — whoever holds the document — spends alone, degrading the two-factor property; adds Draft-status Miniscript and a CSV satisfaction path to the trusted signer; per-UTXO age creates an "old coin vs young change" problem; incompatible with plain-multisig addresses.
Cloned / spare Key B (2-of-2)	cloning key B contradicts the non-exportable-key property a secure element is chosen for, and creates copy-control and replacement hazards; an independent third leg C is simpler and stronger.
Encrypted key-B export	the exported key is a high-value copy with its own copy-control, storage, and destruction ceremony — the most operationally demanding option and the easiest to mishandle.
Single-sig	no redundancy; one loss is total loss; rejected outright.

TIMELOCK WITNESS ORDERING – CORRECTED, FOR THE RECORD ONLY

If a timelock were ever revisited, note the earlier draft got the witness ordering wrong. The compiled script `<A> CHECKSIGVERIFY <B> CHECKSIG IFDUP NOTIF <N> CHECKSEQUENCEVERIFY ENDIF` consumes A's signature first, so `sig_A` must sit directly beneath the witnessScript: `corrected normal [ sig_B, sig_A, WS ], recovery [ <empty>, sig_A, WS ]`. A partial signature is not a proven spend — any such claim needs an independently finalized raw transaction and `testmempoolaccept`. Recorded only because the timelock is rejected, not adopted; the primary policy is 2-of-3 with no timelock.

Architecture selected – what remains before any funding

Done: the recovery architecture is selected — native 2-of-3 P2WSH across A1 (encrypted document) + B (Key Card) + C (Emergency Card/Kit), bearer cards with no PIN, an interchangeable terminal, A2 duplicated on both cards, and the kit tiers above. **Open (stop-ship):**

1. **Confirm the recovery bundle in rehearsal** (§3b): descriptor D (two checksummed receive/change descriptors) on both cards plus one redundant A2-encrypted cloaked copy; the frozen A1 capsule (ChaCha20-Poly1305, stored 96-bit nonce, 128-bit tag); and least-authority account-xprv provisioning of B and C (root mnemonics wiped once the account xpub is confirmed, B and C not derived from A or one master, recovered via the surviving threshold pair and the open rescue tool rather than an exported word list).
2. **Rehearse the loss matrix with real artifacts:** A1+C recovery after B loss, B+C after A1 loss, a lost-factor rotation into a fresh A'/B'/C'/A2'/D' kit with a full sweep, terminal replacement, descriptor-loss confirmation, and an inheritance hand-off — each finalized and independently verified.
3. **Clear the transport blocker:** both QR and microSD are required; microSD (binary PSBT v0 only, no base64/hex autodetection) is the lower-risk first path; QR capture/reassembly on the existing enclosure/optics/320x240 display remains a hardware/system validation blocker with no mechanical redesign authorized. BBQr (file type P, uncompressed base32) is the selected v1 PSBT framing — only its performance on the fixed mechanics remains to benchmark.
4. **Prove entropy reaches the conditioner:** domain-separated acquisition for Seed A/B/C and A2; build-time reachability checks and fault injection (the ColdCard 2026 lesson — health tests alone can't prove the intended source is used).
5. **Freeze the descriptor** only after 1–4, and only then fund it.

BOTTOM LINE

The architecture question is closed: standard 2-of-3 multisig redundancy over any custom recovery protocol — a recovery story that can be explained and rehearsed with independent tooling is worth more than an elegant one only QK2 understands. What remains open is proving it with real cards, documents, devices, and transactions.

QK2 Recovery Decision · settled architecture · memo v7 · 2026-08-17

Recast to the settled 2-of-3 P2WSH product direction: three custody objects (A1 encrypted document + A2 key duplicated on both cards, B Key Card, C Emergency Card/Kit) plus an interchangeable terminal, bearer cards with no PIN, kit tiers, and a rehearsal stop-ship. Timelock, cloned-B, encrypted key-B export and single-sig are rejected. Selected product direction, not implemented or validated. Companion to the QK2 Blueprint, Card Protocol, Descriptor record, and Recovery Document.